MAJOR PROJECT

SOFTWARE REQUIREMENTS SPECIFICATION

AI-Driven Multimodal Step-Up Authentication System with Real-Time Deepfake Detection

---

Student Name	Snigdha Dwivedi
Enrollment No.	2023BTCSE018
JLU ID	JLU08236
Program	B.Tech, Computer Science & Engineering
Faculty	Faculty of Science & Technology (FAST)
University	Jagran Lakecity University, Bhopal
Project Supervisor	Dr. Dileep Kumar Singh
Document	Software Requirements Specification (SRS)
Standard Followed	IEEE Std 830-1998

Table of Contents

Table of Contents 2
1. Introduction 4
1.1 Purpose 4
1.2 Scope 4
1.3 Definitions, Acronyms, and Abbreviations 5
1.4 References 5
1.5 Overview of the Remainder of this Document 5
1.6 Literature Review: Comparative Analysis 6
2. System Workflow and Diagrams 7
2.1 Transaction Risk Evaluation Criteria 7
2.2 Visual Liveness Criteria 7
2.3 Verification Decision Rules 8
2.4 System Diagrams 8
2.4.1 User Flow Diagram 8
2.4.2 Data Flow Diagram (Level 1) 9
2.4.3 System Architecture Diagram 10
3. Functional and Non-Functional Requirements 11
3.1 Functional Requirements 11
FR-1: User Registration & Biometric Enrollment 11
FR-2: Transaction Initiation 11
FR-3: Transaction Risk Scoring 11
FR-4: Step-Up Challenge Invocation 11
FR-5: Vision Liveness Verification 12
FR-6: Audio Capture & Code Verification 12
FR-7: Voice Authenticity Verification 12
FR-8: Multimodal Decision Fusion 12
FR-9: Audit Logging 12
FR-10: Administrator Review Dashboard 13
3.2 Non-Functional Requirements 13
NFR-1: Latency 13
NFR-2: Security 13
NFR-3: Throughput & Scalability 13
NFR-4: Fail-Closed Policy 13
NFR-5: Accessibility 13
NFR-6: Reliability & Data Integrity 13

NFR-7: Maintainability 13
NFR-8: Data Privacy 14
4. Database Schema and API Contracts 15
4.1 PostgreSQL Database Schema 15
4.1.1 Table: users 15
5. Testing Plan and Project Timeline 16
5.1 Test Matrix 16
5.2 Development Timeline 17

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the complete set of functional and non-functional requirements for the AI-Driven Multimodal Step-Up Authentication System with Real-Time Deepfake Detection. The purpose of this document is to establish an unambiguous, verifiable, and formally structured statement of the system's intended behaviour so that it may serve simultaneously as (a) an academic deliverable for evaluation by the project supervisor and the examination panel of the Faculty of Science & Technology, Jagran Lakecity University, (b) a reference baseline against which the design and implementation phases of the project can be validated, and (c) a shared understanding of scope between the student developer and all stakeholders involved in reviewing the project. This document is written in conformance with the structure recommended by IEEE Std 830-1998, adapted to the scale and academic context of a B.Tech major project.

1.2 Scope

The system under specification, henceforth referred to as the Multimodal Step-Up Authentication System (MSAS), is a web-based security layer intended to be invoked at the point of transaction authorisation within a FinTech or digital-banking web application. The MSAS is responsible for computing a contextual risk score for each initiated transaction, determining whether additional verification is required, and, where required, conducting a combined visual-liveness and voice-authenticity challenge referred to as "Look & Speak" before rendering a final Allow, Escalate, or Deny decision.

The scope of this project explicitly includes: the design and prototype implementation of the transaction risk-scoring engine; the design and prototype implementation of the camera-based liveness verification module; the design and prototype implementation of the microphone-based speech transcription and voice-authenticity verification module; the design of a multimodal decision-fusion mechanism; the design of an immutable audit-logging subsystem; and the design of a minimal administrative review dashboard. The scope explicitly excludes the implementation of a complete, production-grade core banking system; integration with any live bank, payment gateway, or telecom operator; formal regulatory certification (for example, under Reserve Bank of India guidelines); native mobile applications for iOS or Android; and the use of dedicated hardware secure elements. The prototype is intended to demonstrate the architecture, decision logic, and interaction flow of the proposed system within a web-browser environment using simulated or sandboxed transaction data.

1.3 Definitions, Acronyms, and Abbreviations

Term	Definition
ASR	Automatic Speech Recognition — converting spoken audio into text.
Deepfake	Synthetic AI-generated video or image that convincingly manipulates a person's likeness.
Fail-Closed	A design principle where failure, ambiguity, or timeout defaults to denial rather than approval.
KYC	Know Your Customer — the identity-verification process used by financial institutions.
Liveness Detection	Techniques confirming a biometric sample comes from a live human, not a replay or synthetic source.
LLM	Large Language Model — used here for structured, explainable multimodal decision fusion.
MSAS	Multimodal Step-Up Authentication System — the system specified by this document.
OTP	One-Time Password — a single-use possession-based authentication factor.
Reticle	An on-screen guide instructing a user to position their face within the camera frame.
SIM-Swap Fraud	Social engineering that convinces a telecom operator to reassign a victim's number to a new SIM.
Step-Up Authentication	Requesting additional verification only when contextual risk exceeds a defined threshold.
Voice Cloning / TTS	Text-to-speech or voice-conversion techniques that imitate a target individual's voice.
WCAG	Web Content Accessibility Guidelines — the standard for web accessibility.
WebRTC	Web Real-Time Communication — enables low-latency browser audio/video capture and streaming.

1.4 References

- IEEE Std 830-1998, IEEE Recommended Practice for Software Requirements Specifications.
- NIST SP 800-63B, Digital Identity Guidelines — Authentication and Lifecycle Management.
- Web Content Accessibility Guidelines (WCAG) 2.1, W3C.
- OWASP Application Security Verification Standard (ASVS).
- MediaPipe Documentation, Google AI Edge — Face Landmarker / Face Mesh solutions.
- Whisper: Robust Speech Recognition via Large-Scale Weak Supervision, OpenAI.

1.5 Overview of the Remainder of this Document

Section 2 describes the system workflow in plain English, including risk-evaluation and liveness criteria, decision rules, and diagrams. Section 3 lists all functional (FR-1 to FR-10) and non-functional (NFR-1 to NFR-8)

requirements. Section 4 specifies the database schema and API contracts. Section 5 presents the testing plan and development timeline.

1.6 Literature Review: Comparative Analysis

The table below situates the proposed Multimodal Step-Up Authentication System (MSAS) against five authentication methods presently used across digital banking, highlighting the weaknesses that motivate this project.

Method	Strength	Weakness	Deepfake Resistance
SMS OTP	Simple, no hardware needed.	SIM-swap and SS7 interception defeat it; no liveness check.	Very Low
Static Face ID	Fast, low friction.	Defeated by printed photos, screen replay, or static deepfakes.	Low
Hardware Tokens	Strong, remote-attack resistant.	Costly to distribute; impractical for mass-market retail banking.	High (impractical at scale)
Voice Biometrics (static)	Convenient, hands-free.	Vulnerable to voice cloning and passphrase replay.	Low–Moderate
Video KYC (human-led)	High assurance with trained agents.	Not scalable; expensive; still fooled by good deepfakes.	Moderate
Proposed MSAS	Adaptive, multimodal, randomised, auditable, fail-closed.	Needs camera/mic and good network quality.	High

No incumbent method combines contextual risk adaptivity, multimodal redundancy, and randomised challenge-response verification in one pipeline. SMS OTP and static Face ID remain popular for being cheap and low-friction, yet are the easiest to defeat with SIM-swap fraud and deepfakes. Hardware tokens and human-led Video KYC are stronger but too costly to apply per transaction. The proposed MSAS is designed to fill this gap: low friction for routine transactions, escalating automatically to a strong multimodal challenge only when risk justifies it.

2. System Workflow and Diagrams

2.1 Transaction Risk Evaluation Criteria

The Transaction Risk Engine evaluates every initiated transaction against a small set of contextual indicators before any biometric challenge is considered, combining them into an overall risk tier of Low, Medium, or High.

Transfer Amount: the value of the transaction is compared against the account holder's typical transaction size; unusually large transfers contribute more strongly to risk.

Location Change: the session's approximate location is compared against locations the account has recently and reliably used; transactions from a new city or country raise the risk contribution.

Device Velocity: the system checks how many distinct devices have been used recently and how quickly the account has switched between them; a sudden new device is treated as an elevated signal, especially if it follows recent activity on a different device.

Time-of-Day Pattern: transactions attempted at times markedly inconsistent with the account holder's usual activity add a mild contribution to the overall score.

Payee Risk: transfers to a first-time or watch-listed payee are treated as riskier than transfers to an established, frequently used payee.

A cumulative score below the lower threshold results in silent approval (Low tier); a score between the two thresholds triggers the Look & Speak challenge (Medium tier); a score above the upper threshold triggers the challenge together with mandatory escalation to human review regardless of outcome (High tier).

2.2 Visual Liveness Criteria

Natural Eye-Blink Detection: the Vision Core observes the relative opening and closing of the eyes across frames; a live subject blinks involuntarily at irregular intervals, while the complete absence of blinking, or mechanically regular blinking, indicates a photo or video replay.

Head Movement Prompt: a randomly chosen instruction (for example, turning the head gently to one side) is issued, and the system checks whether facial landmarks move in a manner consistent with genuine three-dimensional rotation — a cue that a flat photo, screen replay, or real-time deepfake struggles to reproduce convincingly within a short, unpredictable time window.

Reticle-Guided Positioning: an on-screen guide requires the user to keep their face within a defined region and distance, ensuring reliable landmark extraction and forcing an attacker to dynamically align a physical artefact with a moving target, which is considerably harder than presenting a static image to an unguided camera.

A verification attempt is considered visually live only if all three cues are jointly satisfied within the active capture window, typically around eight seconds.

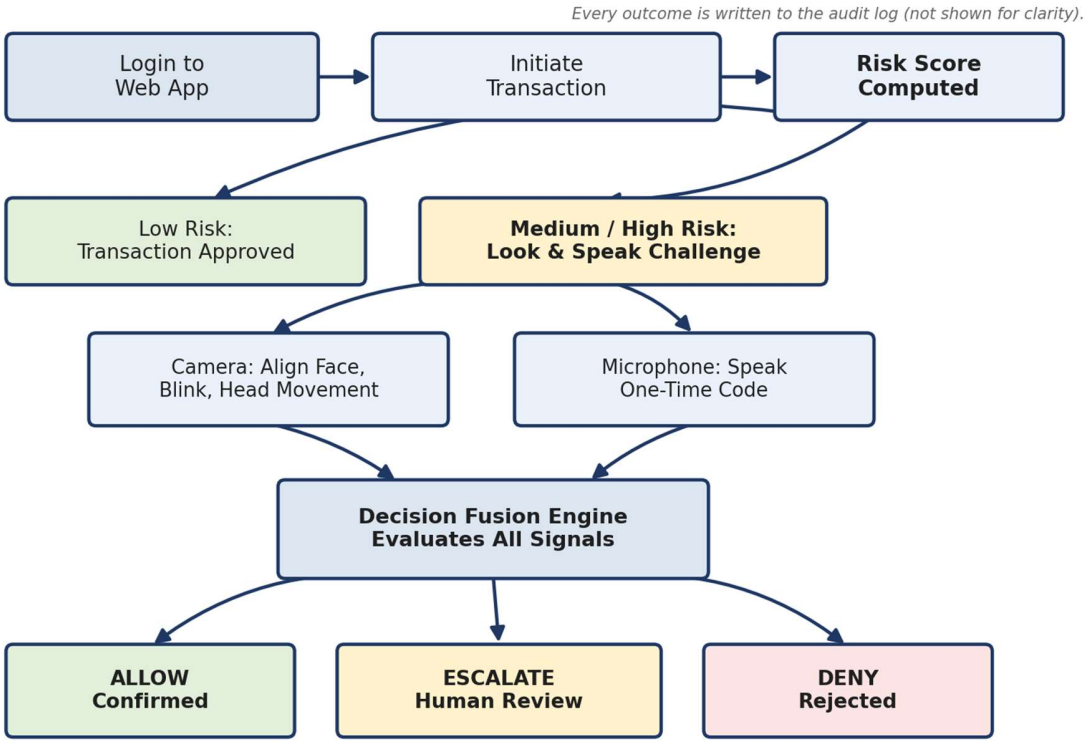
2.3 Verification Decision Rules

The final decision combines the visual liveness verdict, the spoken code match result, the voice authenticity check, and the transaction risk tier, reasoned through step by step like a checklist rather than a single opaque calculation. When all three verification signals pass, the transaction is allowed. When the code and vision checks pass but the audio is flagged as potentially synthetic, the case is escalated to human review before funds are released. When the visual liveness check fails, or when the vision and audio checks fail simultaneously, the transaction is denied outright, and a simultaneous failure additionally flags the account for security review irrespective of transaction value. If the spoken code does not match, a limited retry is permitted before the attempt is denied. In keeping with the fail-closed design principle described in NFR-4, any component timeout, network failure, or ambiguous score defaults to denial or escalation rather than silent approval.

2.4 System Diagrams

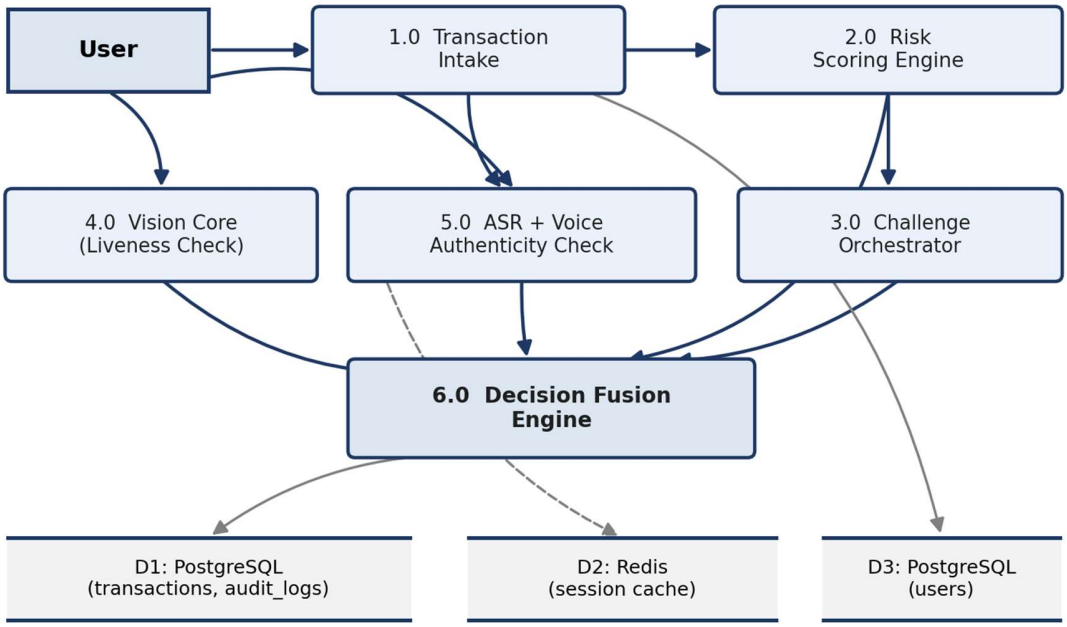
2.4.1 User Flow Diagram

The diagram below traces the end-to-end journey of a user from login through transaction initiation, the optional Look & Speak challenge, and the final decision.



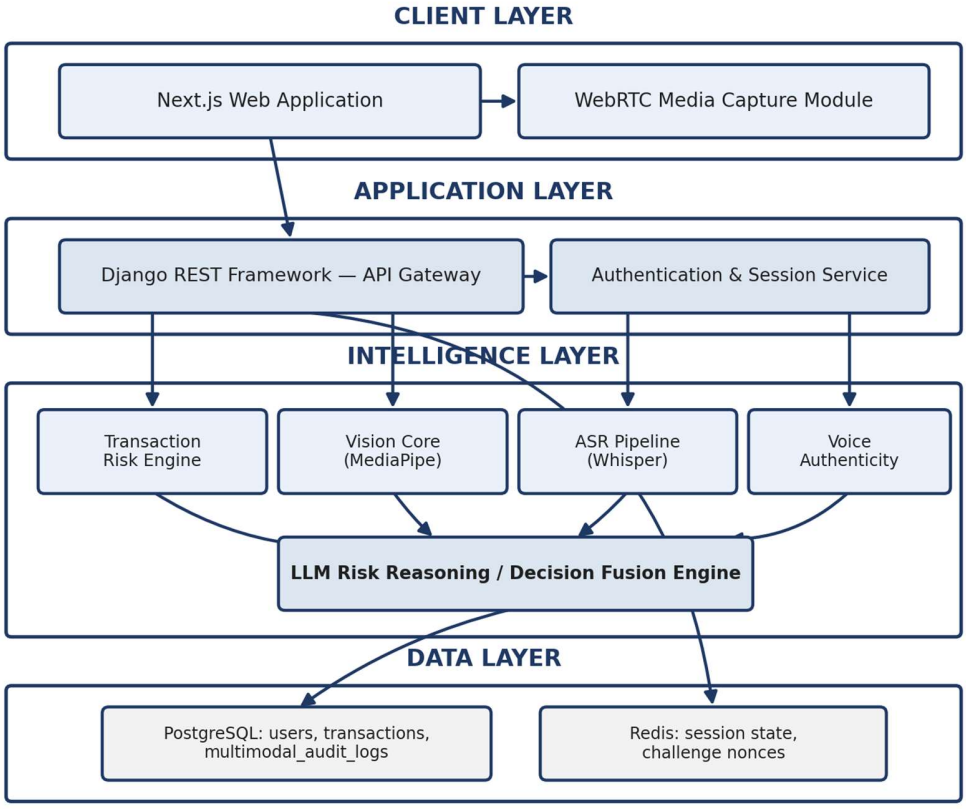
2.4.2 Data Flow Diagram (Level 1)

The Level 1 Data Flow Diagram identifies the external entity (the User), the six principal processes performed by the system, and the data stores used to persist transaction, session, and audit information.



2.4.3 System Architecture Diagram

The system architecture is organised into four logical layers, shown below: the Client Layer, the Application Layer, the Intelligence Layer, and the Data Layer.



3. Functional and Non-Functional Requirements

3.1 Functional Requirements

Each requirement below states its input, processing logic in plain English, expected output, and the criteria used to judge pass or fail during testing.

FR-1: User Registration & Biometric Enrollment

Input: Personal details, a reference selfie/video, and a reference voice sample.

Processing: The system checks basic liveness and quality in the enrollment media, then derives and stores facial and voice feature templates rather than raw media, linked to a new user record.

Output: Enrollment confirmation and a unique user ID.

Pass/Fail: Succeeds only if the reference media passes minimum liveness and quality checks; otherwise it is rejected with a clear error.

FR-2: Transaction Initiation

Input: Payer, payee, amount, currency, description.

Processing: Validates the payer's balance and the payee format, creates a pending transaction record, and forwards metadata to the Risk Engine.

Output: Transaction ID and initial routing decision.

Pass/Fail: A valid request always yields a persisted record and a decision within the latency budget; invalid requests are rejected without creating a record.

FR-3: Transaction Risk Scoring

Input: Transaction metadata, device fingerprint, geolocation, historical profile.

Processing: Evaluates amount, location, device velocity, time pattern, and payee risk (Section 2.1) into a cumulative score mapped to a risk tier.

Output: Numeric score and tier label.

Pass/Fail: Matches the expected tier for a defined test set, computed within the latency budget.

FR-4: Step-Up Challenge Invocation

Input: A Medium/High risk transaction.

Processing: Generates a random, single-use challenge phrase, caches it in Redis with an expiry, and opens a secure WebRTC session.

Output: Challenge payload delivered to the client.

Pass/Fail: Every challenge is unique, expires on schedule, and can be used exactly once.

FR-5: Vision Liveness Verification

Input: Live video during the challenge window.

Processing: MediaPipe extracts facial landmarks to check blink pattern, head-pose response, and reticle alignment (Section 2.2).

Output: Pass/Fail verdict with confidence indicators.

Pass/Fail: All three cues are evaluated within the capture window; no face detected returns Fail, never an indeterminate result.

FR-6: Audio Capture & Code Verification

Input: Live audio of the spoken challenge phrase.

Processing: Whisper transcribes the audio and compares it to the displayed phrase within a small tolerance.

Output: Match result and transcript text.

Pass/Fail: Correct speech matches in the large majority of trials; incorrect or absent speech is rejected.

FR-7: Voice Authenticity Verification

Input: The same audio stream as FR-6.

Processing: A classifier examines spectral and prosodic patterns for artefacts typical of synthetic or cloned speech.

Output: Authenticity score and synthetic-audio flag.

Pass/Fail: Known synthetic samples are consistently flagged; genuine benchmark recordings are not, within tested accuracy bounds.

FR-8: Multimodal Decision Fusion

Input: Vision verdict, code match, authenticity flag, risk tier.

Processing: The LLM Risk Engine applies the rules in Section 2.3 step by step and drafts a plain-language rationale.

Output: Final decision (Allow / Escalate / Deny) with rationale.

Pass/Fail: Every defined signal combination returns the expected outcome, always with a non-empty rationale.

FR-9: Audit Logging

Input: Every event from initiation through final decision.

Processing: Compiles scores, verdicts, and the decision into a structured record with a media hash reference and timestamp.

Output: A unique audit log ID linked to the transaction and user.

Pass/Fail: Every attempt, regardless of outcome, produces exactly one durable audit record.

FR-10: Administrator Review Dashboard

Input: Administrator login and optional filters.

Processing: Authenticates the administrator, checks role permissions, and queries audit logs by the given filters.

Output: Filtered, paginated case list with a resolve action.

Pass/Fail: Accessible only to administrators; escalated cases appear within a defined refresh interval; resolutions record reviewer identity and time.

3.2 Non-Functional Requirements

The following quality attributes and constraints apply system-wide, in addition to the functional behaviour above.

NFR-1: Latency

The complete Look & Speak sequence must complete within three seconds under standard broadband or 4G conditions, to keep the step-up experience usable.

NFR-2: Security

All data in transit is encrypted with TLS 1.3; biometric data is stored as irreversible feature templates, not raw media; access is governed by role-based control and signed, time-limited session tokens.

NFR-3: Throughput & Scalability

The system supports at least five hundred concurrent verification sessions with a failure rate below one percent.

NFR-4: Fail-Closed Policy

Any component failure, timeout, or ambiguous score anywhere in the pipeline defaults to Deny or Escalate, never a silent Allow.

NFR-5: Accessibility

The interface conforms to WCAG 2.1 AA, with captioned instructions, screen-reader-compatible labels, adequate contrast, and a supervised fallback path for users unable to use a camera or microphone.

NFR-6: Reliability & Data Integrity

The Risk Engine and audit log target 99.5 percent uptime in staging, and every audit record is durable and tamper-evident.

NFR-7: Maintainability

The Risk Engine, Vision Core, ASR Pipeline, Voice Authenticity Classifier, and Decision Fusion Engine are loosely coupled so any one module can be updated or retrained independently.

NFR-8: Data Privacy

The system follows data-minimisation principles, captures explicit consent before enrollment, supports configurable retention periods, and is broadly aligned with the Information Technology Act, 2000, while formal certification remains outside this academic prototype's scope.

4. Database Schema and API Contracts

4.1 PostgreSQL Database Schema

The relational schema below defines the three core tables required by the prototype: users, for account and enrollment data; transactions, for transaction and risk-scoring records; and multimodal_audit_logs, for the immutable record of every authentication decision. All primary keys are implemented as universally unique identifiers (UUIDs) to avoid predictable sequential identifiers in a security-sensitive schema.

4.1.1 Table: users

Column	Data Type	Key / Constraint	Description
id	UUID	Primary Key	Unique user identifier, generated on registration.
full_name	VARCHAR(150)	Not Null	Full legal name of the account holder.
email	VARCHAR(255)	Unique, Not Null	Registered email, used for recovery and notifications.
phone_number	VARCHAR(15)	Unique, Not Null	Registered mobile number.
password_hash	VARCHAR(255)	Not Null	Salted hash of the login password; raw password never stored.
device_fingerprint	VARCHAR(255)	Nullable	Most recently recognised device, used for device-velocity scoring.
face_embedding_ref	VARCHAR(255)	Nullable	Pointer to the stored facial feature template; raw images not stored.
voice_embedding_ref	VARCHAR(255)	Nullable	Pointer to the stored voice feature template; raw audio not stored.
account_tier	VARCHAR(20)	Default 'STANDARD'	Account class used to calibrate amount-risk thresholds.
status	VARCHAR(20)	Default 'ACTIVE'	ACTIVE, SUSPENDED, or UNDER_REVIEW.
created_at / updated_at	TIMESTAMP	Not Null	Record creation and last-modified timestamps.

5. Testing Plan and Project Timeline

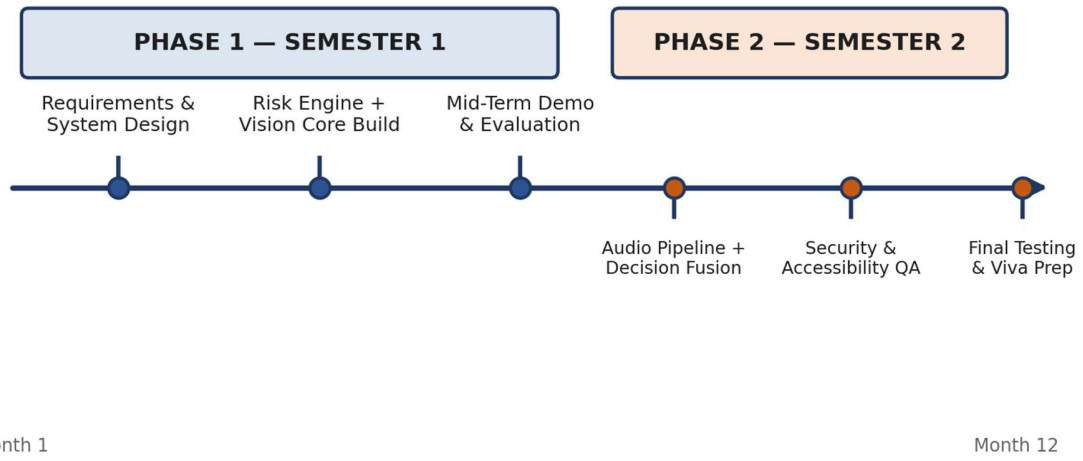
5.1 Test Matrix

The ten scenarios below cover legitimate usage, common presentation attacks, environmental degradation, and infrastructure failure, validating both the functional requirements of Section 3.1 and the fail-closed policy of NFR-4.

Test ID	Scenario	Input Condition	Expected Result
TC-01	Legitimate low-risk transaction	Small routine transfer, recognised device/location.	Approved silently, no challenge.
TC-02	Legitimate high-value transaction	Large transfer, correct live face and voice.	Challenge invoked; both checks pass; ALLOW.
TC-03	Photo spoofing attack	Printed/on-screen photo shown to camera.	No natural blink/head-pose response; DENY.
TC-04	Video replay attack	Pre-recorded video played on a second screen.	Reticle/head-pose prompt fails dynamically; DENY.
TC-05	Deepfake voice clone playback	Synthetic voice speaks the correct code.	Authenticity classifier flags it; ESCALATE/DENY.
TC-06	Correct voice, wrong spoken code	Live user misreads the displayed code.	ASR mismatch; limited retry, then DENY.
TC-07	Low-light environment	Poor lighting degrades landmark confidence.	System prompts recapture instead of a false DENY.
TC-08	Network dropout mid-verification	Connectivity lost during the WebRTC session.	Fail-closed: transaction held PENDING, retry required.
TC-09	New device + SIM-swap-like pattern	Unseen device, high-value transfer.	High risk tier; mandatory challenge + human review.
TC-10	Concurrent load test	500 simultaneous verification sessions.	≥99% complete within the 3-second latency budget.

5.2 Development Timeline

The project follows a two-phase, one-year plan aligned with the academic semester structure. Phase 1 (Semester 1) establishes the system design, the transaction risk engine, and the visual liveness module, culminating in a mid-term demonstration. Phase 2 (Semester 2) builds the audio verification pipeline and the multimodal decision fusion engine, then moves through security hardening, full test-matrix execution, and final documentation ahead of the viva-voce examination.



This phased structure ensures each module builds on a previously validated foundation: the risk-scoring and vision-liveness components from Semester 1 provide the infrastructure and test discipline for the audio-verification and decision-fusion components undertaken in Semester 2, culminating in a fully integrated and tested prototype.